Agentic Detection of Security Antipatterns in Microservices Architectures

Analysing Security Vulnerabilities in Human Written and AI generated Microservices

M. Shazil Khan, Ahsen Tahir, Francis Palma

SE+AI Research Lab, Faculty of Computer Science, UNBF

UNB
EST. 1785
UNIVERSITY OF NEW BRUNSWICK

Science Atlantic | Science Atlantique
MSCS
Mathematics & Statistics and Computer Science Conference
Conférence en mathématiques et statistique et en informatique

Hello, I'm Muhammad Shazil Khan

Visiting AI Researcher From Pakistan at University of New Brunswick, Fredericton

Working under the supervision of **Prof. Francis Palma**

https://mshazilkhan.vercel.app/



Context

- Different microservices in Software Engineering world

- Multiple security vulnerabilities exists in microservices

- Code level and Design level Vulnerabilities

- Detection of these security vulnerabilites is important

SE+AI RESEARCH LAB

UNB EST. 1785 UNIVERSITY OF NEW BRUNSWICK

The Problem

- Microservice security flaws often come from architectural decisions, not coding bugs

- Examples: bypassing the API gateway, services with excessive privileges

- Static analysis tools and LLM code-security studies focus on code-level weaknesses

- Design-level security antipatterns are largely unexamined

SE+AI RESEARCH LAB

UNB EST. 1785 UNIVERSITY OF NEW BRUNSWICK

9 Design Level Security Antipatterns

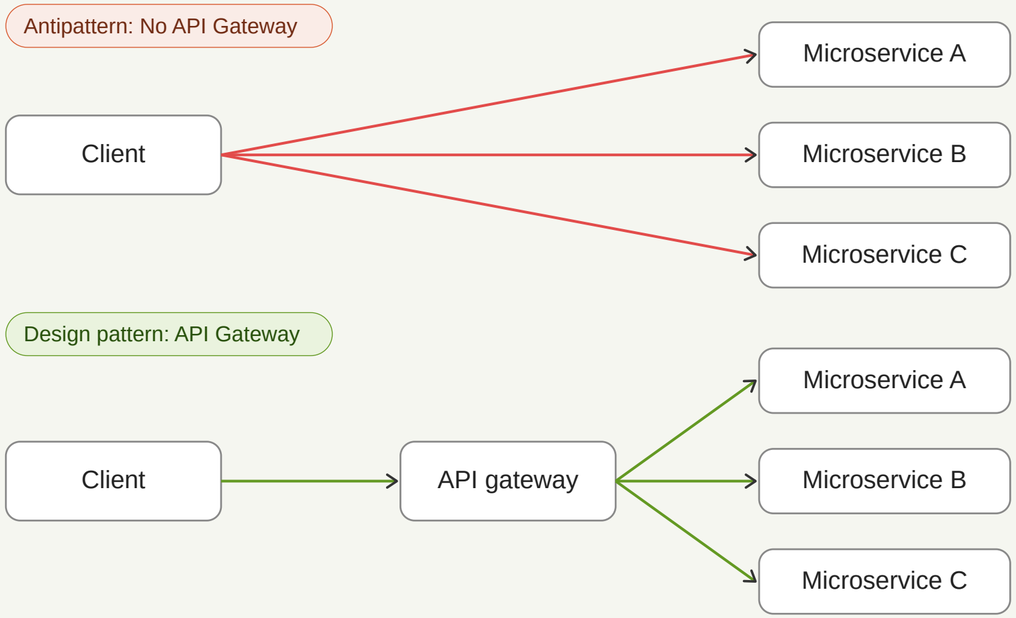
1. Centralized Authorization
2. Insufficient Access Control
3. Multiple Inconsistent Authentication
4. No API Gateway
5. Non-Secured Service-to-Service Communication
6. Publicly Accessible Microservices
7. Unauthenticated Traffic
8. Unnecessary Privileges
9. Unvalidated Service Registration

SE+AI RESEARCH LAB

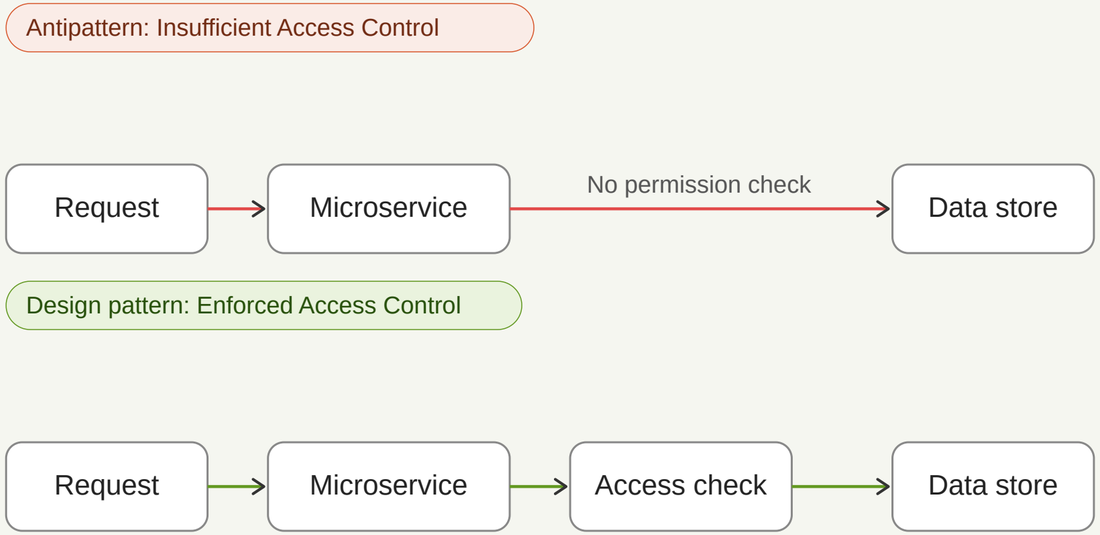
EST. 1785 UNB UNIVERSITY OF NEW BRUNSWICK

Antipattern Example

No Api Gateway



Insufficient Access Control

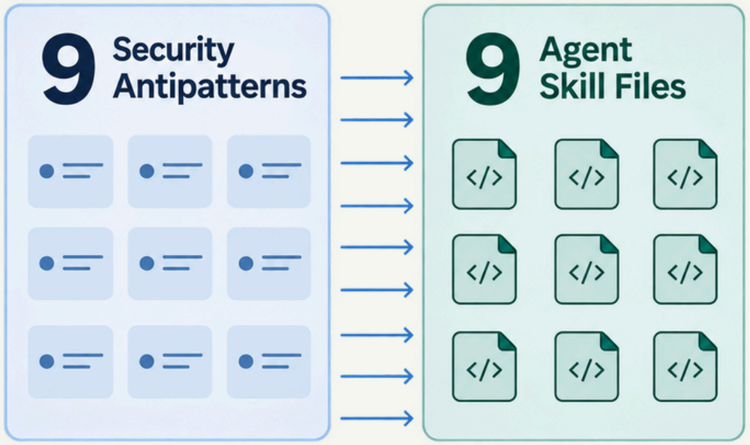


SE+AI RESEARCH LAB

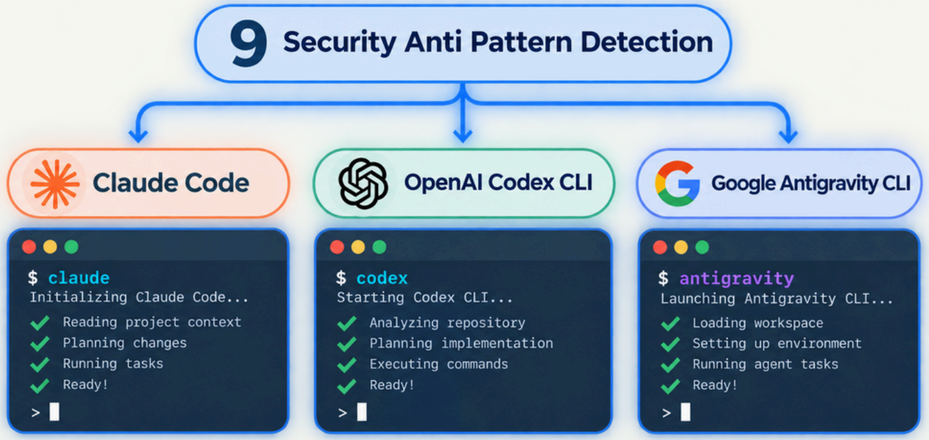
UNB EST. 1785 UNIVERSITY OF NEW BRUNSWICK

Research Methodology: Overview

- 9 security antipatterns, each with detection criteria and not-applicable conditions



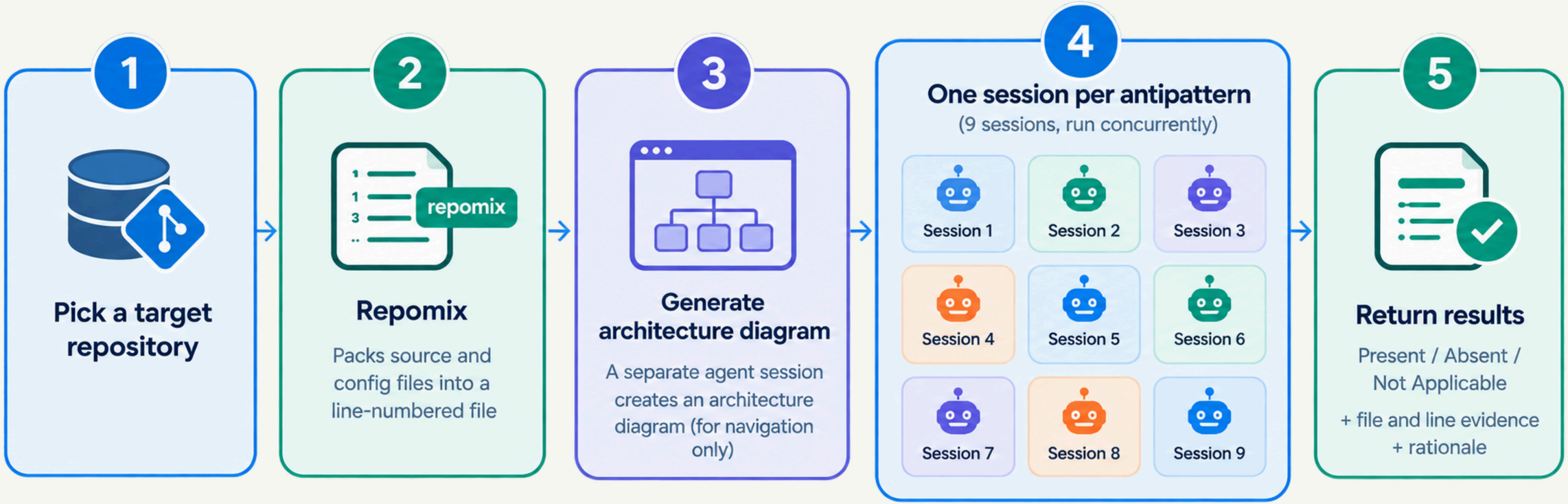
- 3 coding agents run through their CLIs: Claude Code, OpenAI Codex CLI, Google Antigravity CLI



SE+AI RESEARCH LAB

EST. 1785 UNB UNIVERSITY OF NEW BRUNSWICK

Research Methodology: Detection Pipeline



SE+AI RESEARCH LAB

UNB EST. 1785 UNIVERSITY OF NEW BRUNSWICK

Dataset Creation and Ground Truth

- **20 open-source** microservice repositories
- Two independent expert raters annotate each repository
- A third expert adjudicates disagreements
- The result is the **human-validated ground truth** for benchmarking the agents

Research Questions

RQ1: Prevalence

How prevalent are security antipatterns in developer-written microservices?

RQ2: Model Comparison

How does the choice of coding agent affect the security antipattern profiles of AI-generated microservices?

RQ3: Prompting Effects

How do different prompting strategies affect the security of AI-generated microservices?

RQ4: Detection Effectiveness

How effectively can our proposed ADAM method detect security antipatterns in microservices?

Preliminary Results

- Experiments completed on the 20 repositories with all 3 AI agents

- **Metrics**: Accuracy, precision, recall, F1-score per agent

Coding agents vs human validation

Agent	Accuracy	Precision	Recall	F1 score
Claude	87.2%	83.5%	84.2%	83.7%
Codex	83.3%	85.5%	74.8%	76.1%
Antigravity	85.6%	82.5%	80.3%	80.4%

180 findings (20 repos x 9 smells). Precision, recall and F1 are averaged over present / absent / not applicable. Green = best.

SE+AI RESEARCH LAB

UNB EST. 1785 UNIVERSITY OF NEW BRUNSWICK

Ongoing Work

- Generating Microservices via AI agents
- Running the detecting pipeline on AI generated Microservices
- Comparing different Prompting Strategies on the microservice generation
- Analysing Detection capabilites on individual microservices

SE+AI RESEARCH LAB

UNB EST. 1785 UNIVERSITY OF NEW BRUNSWICK

Thank You

Do you have any question? Feel free to ask.

SE+AI RESEARCH LAB

UNB EST. 1785 UNIVERSITY OF NEW BRUNSWICK